

Ataques DDoS por Reflexão Amplificada Sobre Refletor IoT Rodando CoAP

Amplified Reflection DDoS Attacks over IoT Reflector Running CoAP

Alan Tamer Vasques

Departamento de Engenharia Elétrica
Universidade de Brasília (UnB)
alan.tamer@aluno.unb.br

João J. C. Gondim

Departamento de Ciência da Computação
Universidade de Brasília (UnB)
gondim@unb.br

Resumo — No contexto dos ataques distribuídos de negação de serviço (DDoS), os ataques por reflexão amplificada (AR-DDoS) representam uma tendência que vem se intensificando. Recentemente, houve relatos de ataques AR-DDoS explorando CoAP, um protocolo tipicamente utilizado na Internet das Coisas (IoT). Com esta motivação, o ataque AR-DDoS abusando CoAP, executado em um dispositivo IoT típico, sobre IPv4 e IPv6, é estudado. Os resultados observados são consistentes com estudos anteriores e caracterizam a saturação do refletor para baixas taxas de injeção de *probes*.

Palavras Chave - DDoS, IoT, CoAP, Saturação de Refletores, Reflexão Amplificada.

Abstract — In the context of distributed denial of service (DDoS) attacks, those which use amplified reflection (AR-DDoS) are a growing trend. Recently, AR-DDoS attacks exploring CoAP, a typical Internet of Things (IoT) protocol, were reported. With this motivation, the AR-DDoS attack abusing CoAP running on a typical IoT device, over IPv4 and IPv6, is studied. The results observed are consistent with previous studies and characterize reflector saturation at low probe injection rates.

Keywords - DDoS, IoT, CoAP, Mirror Saturation, Amplified Reflection.

I. INTRODUÇÃO

Os ataques volumétricos de negação de serviço distribuído (DDoS) demonstram uma crescente nos últimos anos, como no ataque contra SpamHaus [1] [2], que quebrou a barreira psicológica de 100 Gbps, atingindo mais de 300 Gbps, e nos ataques da *botnet* Mirai, que atingiram mais de 1 Tbps. Enquanto o primeiro consolidou o uso da reflexão amplificada, o último abusou de mais de 145 mil dispositivos da Internet das Coisas (IoT) [3]. Esses dois incidentes foram os principais fatores de mudança no DDoS volumétrico e definiram tendências em novos ataques. Em 2018, dois incidentes [4] [5], com quatro dias de intervalo, envolvendo DDoS por reflexão amplificada (AR-DDoS), estabeleceram o recorde de ataques volumétricos atingindo 1,35Tbps e 1,7Tbps, respectivamente. Nos dois casos, o Memcache foi o protocolo de aplicação abusado.

Recentemente, já ocorreram ataques AR-DDoS explorando o *Constrained Application Protocol* (CoAP) [6], em dispositivos IoT [7]. O CoAP tem uso típico em aplicações IoT, sendo muito utilizado para a troca de informações entre equipamentos com

poder de processamento mais limitado, como *smartphones*, pontos de acesso sem fio, terminais *Gigabit Passive Optical Network* (GPON) e outros dispositivos IoT. Assim, se estabelece uma clara ligação entre ataques AR-DDoS e IoT. Entretanto, as características do AR-DDoS explorando CoAP em dispositivos IoT ainda não foram objeto de estudo.

A. Trabalhos relacionados

Preocupações com a segurança de IoT tem sido um tema recorrente, como em [8]. [9] discute o AR-DDoS inicialmente como ataques DDoS que falsificam solicitações da vítima para um grande conjunto de servidores da Internet que, por sua vez, enviam suas respostas combinadas à esta. [10] revisita os ataques AR-DDoS quando se tornaram *mainstream*, abrangendo aplicações baseadas em UDP de serviços de rede, jogos *online*, redes de compartilhamento de arquivos e *botnets* P2P e avaliando sua segurança contra o abuso de AR-DDoS.

Uma série de trabalhos estuda a dinâmica do AR-DDoS: [11] simula uma pilha IoT típica e observa a saturação do refletor usando um ataque AR-DDoS para explorar vulnerabilidades de segurança da IoT; [12] avalia os possíveis impactos dos ataques de negação de serviço distribuído de reflexão amplificada (AR-DDoS), usando uma abordagem empírica para examinar a ameaça representada pela execução do ataque em um ambiente controlado; [13] usa a metodologia usada em [12] para comparar o comportamento de saturação do refletor AR-DDoS nos protocolos SNMP e SSDP, constatando que ocorre com taxas de *probe* relativamente baixas, mesmo para refletores com recursos computacionais razoáveis; [14] testa esses mesmos protocolos com dispositivos IoT típicos e confirma o comportamento da saturação do refletor para taxas de *probe* ainda mais baixas.

B. Contribuições

Este trabalho tem por motivação estudar a dinâmica do ataque AR-DDoS explorando CoAP sobre dispositivo IoT. Suas principais contribuições são: caracterizar o comportamento de saturação do refletor quando este é um dispositivo IoT típico, tanto sobre IPv4 quanto IPv6 e contrastar com resultados obtidos com metodologia idêntica em trabalhos anteriores.

II. RESUMO DO ATAQUE AR-DDoS

Segundo [15], os ataques DDoS podem ser de dois tipos: volumétricos ou de baixo volume/taxa lenta. Os ataques de reflexão, foco desse trabalho, se encaixam no primeiro tipo. O objetivo dos ataques volumétricos é inundar a vítima com uma quantidade de tráfego maior do que ela ou o seu enlace é capaz de suportar, sobrecarregando e causando indisponibilidade no serviço oferecido e, consequentemente, impedindo que requisições legítimas sejam tratadas.

Em ataques DDoS, é muito comum ser utilizada a técnica de falsificação de endereço IP, também conhecida como *IP Spoofing*, em inglês. [16] afirma que essa técnica consiste em alterar o campo "endereço de origem" dos cabeçalhos dos pacotes IP, de forma a ocultar o verdadeiro remetente dos pacotes ou personificar outro dispositivo, dificultando a sua localização real. Em ataques AR-DDoS, o campo é preenchido com o endereço da vítima, para que o refletor possa encaminhar as respostas das requisições a ela.

Uma medida importante para calcular o sucesso de um ataque AR-DDoS diz respeito à capacidade de amplificação do ataque por parte do refletor, isto é, o quanto ele é capaz de gerar de resposta comparado com o que recebeu de requisição. Essa medida é chamada de fator de amplificação (FA) e pode ser de dois tipos: *bytes* e *pacotes*, de acordo com as equações (1) e (2), respectivamente.

O cálculo adotado neste trabalho segue o padrão definido por [15], onde o tamanho do datagrama enviado pelo refletor é dividido pelo tamanho do datagrama recebido por ele, em *bytes*, sem considerar o tamanho do cabeçalho Ethernet (ou da tecnologia de enlace que esteja sendo utilizada). Dessa forma, apesar de os fatores de amplificação serem diferentes para ataques com IPv4 e IPv6, eles refletirão de forma mais fidedigna a realidade para cada protocolo, de forma distinta de [10].

$$FA_{\text{Bytes}} = \frac{(Cab\ IP + Cab\ UDP + Dados)_{\text{resposta}}}{(Cab\ IP + Cab\ UDP + Dados)_{\text{requisição}}} \quad (1)$$

De modo similar, também é possível obter o fator de amplificação de pacotes de um ataque, pela razão entre a quantidade de pacotes enviados pelo refletor e a quantidade de pacotes recebidos por ele. Se o datagrama UDP for muito grande e ocorrer fragmentação IP durante a transmissão, os fragmentos também são considerados nos cálculos, uma vez que cabeçalhos adicionais são adicionados, assim como o processamento de todos os fragmentos nos equipamentos envolvidos será necessário.

$$FA_{\text{Pacotes}} = \frac{\text{quantidade de pacotes enviados pelo refletor}}{\text{quantidade de pacotes recebidos pelo refletor}} \quad (2)$$

A. Ataque AR-DDoS Usando CoAP

O protocolo CoAP utiliza mensagens similares ao HTTP, porém é mais leve e opera de forma assíncrona sobre UDP na porta 5683.

A especificação do CoAP define quatro tipos de mensagens: **Confirmable - CON** (confirmável), **Non-confirmable - NON** (não confirmável), **Acknowledgement - ACK** (confirmada) e

Reset - RST (redefinida). Requisições podem ser realizadas por mensagens do tipo CON, onde a confiabilidade entre a troca de informações é requerida ou do tipo NON, quando ela não é necessária. A resposta de uma requisição pode ser do tipo CON, NON ou ACK, essa última sendo utilizada para confirmar o recebimento de uma mensagem do tipo CON. E, quando um destinatário não consegue processar a requisição, ele responde com uma mensagem do tipo RST.

De forma análoga ao HTTP, o CoAP implementa quatro métodos de requisição, que são responsáveis por indicar a ação a ser executada para um dado recurso, que é identificado por uma *Uniform Resource Identifier* (URI): GET, POST, PUT e DELETE.

O ataque baseado no protocolo CoAP utiliza requisições do tipo **Confirmable (CON)**, com método **GET**, pois elas requerem que uma mensagem de resposta seja enviada. A resposta é enviada à vítima no formato de uma mensagem do tipo **Acknowledgment (ACK)**, com código **2.05 Content**, podendo ser do tipo *piggybacked* (quando os dados de resposta vão junto com a mensagem ACK) ou *separate* (quando os dados de resposta vão separadas da mensagem ACK). A figura 1 ilustra o funcionamento de um ataque AR-DDoS usando CoAP.



Figura 1. Ataque AR-DDoS com CoAP

O protocolo CoAP tem uma particularidade que permite que recursos sejam descobertos sem que se conheça como o servidor está estruturado ou configurado. Para isso, basta enviar uma mensagem com método **GET** para o recurso `"/.well-known/core"`, que o servidor retorna com uma lista com todos os recursos que possui. Com isso, o atacante pode previamente testar qual recurso do servidor irá gerar respostas com o maior tamanho possível, ou seja, com maiores taxas de amplificação.

Para personalizar o ataque e maximizar a sua taxa de amplificação, duas opções são utilizadas nas mensagens de requisição do ataque. A primeira opção é a **Uri-Path**, que informa qual será o recurso (URI) a ser consultado e a segunda é a **Block2**, que manipula alguns parâmetros da resposta, como o tamanho que ela deve possuir.

A opção **Uri-Path** é identificada pelo tipo 11 e o seu tamanho é variável, de acordo com o tamanho da URI. Quanto menor a URI, menor será a requisição e, consequentemente, maior será o fator de amplificação do ataque. Caso a URI possua subdiretórios, como em `"/.well-known/core"`, cada diretório será exibido em uma opção diferente, mas todas sendo do mesmo tipo.

A opção **Block2** foi introduzida na RFC 7959 [17] e é identificada pelo tipo 23, possuindo 3 subcampos: **NUM**, **M** e **SZX**. **NUM** representa o número do bloco a ser buscado e é preenchido com "0" para indicar que seria o primeiro. [17]

especifica que, em mensagens de requisição com o código **GET**, o parâmetro **M (More)** não tem função e deve ser preenchida com "0". O subcampo **SZX** indica o tamanho do bloco a ser buscado, ou seja, o tamanho que o *payload* da mensagem de resposta terá. Como o subcampo é representado em potência de 2 e está limitado a 3 bits (variando de 0 a 7 em decimal), é necessário utilizar a equação (3) para determinar o valor do bloco (**SZX**) em *bytes*.

$$\text{Tam}_{\text{bloco}} = 2^{(\text{SZX}+4)} \quad (3)$$

Segundo [17], o valor de **SZX** varia de 0 (bloco de 16 *bytes*) a 6 (bloco de 1024 *bytes*). O valor 7 (teoricamente de 2048 *bytes*) é reservado e deve retornar com uma resposta de erro com código **"4.00 Bad Request"**. Contudo, isso depende da implementação do servidor CoAP e seria necessário testar em cada refletor o comportamento da resposta quando o valor de **SZX** for preenchido com "7".

B. Modus Operandi

Segue um resumo dos passos a serem seguidos para a efetivação de um ataque AR-DDoS utilizando CoAP:

1. Descobrir os recursos existentes no servidor CoAP enviando uma mensagem de requisição para a URI `"/.well-known/core"` e determinar o que possui maior tamanho;
2. Testar se o servidor aceita e gera respostas válidas para requisições com o campo **SZX** configurado para "7" (2048 *bytes*);
3. Gerar uma mensagem **CON** com método **GET**, com valor de **Message ID** aleatório para cada pacote. Em seguida, adicionar a opção do tipo 11 (**Uri-Path**) preenchida com o valor do recurso a ser consultado e a opção do tipo 23 (**Block2**) com valor de **SZX** ajustado para "6" (1024 *bytes*) ou "7" (2048 *bytes*), caso o servidor aceite;
4. Gerar um datagrama UDP com a mensagem **CON** criada no passo 3, com porta de origem aleatória e a porta de destino 5683 (ou a que o refletor esteja utilizando para o CoAP);
5. Adicionar o cabeçalho IPv4/IPv6 ao datagrama UDP, com o endereço de origem forjado para o IP da vítima e o endereço de destino ajustado para o IP do refletor. Em seguida, encaminhar o pacote ao refletor;
6. O refletor recebe a mensagem, a processa e responde desatentadamente com uma mensagem do tipo **ACK** ao endereço da vítima, que estava forjado no pacote.

III. TESTES E METODOLOGIA

Os testes realizados nesse artigo ocorreram em um ambiente controlado com uma ferramenta desenvolvida em C, que permite a realização de ataques com o protocolo CoAP para endereços de vítimas e refletores tanto em IPv4 quanto em IPv6, além da personalização dos parâmetros do CoAP descritos anteriormente por meio de *flags* via linha de comando.

Após testes, foi constatado que o servidor CoAP utilizado no refletor, indicado na tabela I, aceitava requisições com valor de

SZX igual a 7. Desse modo, foi adicionado a ele um recurso que possuía mais de 2048 *bytes* de tamanho e o caminho do recurso foi configurado para ter apenas 1 caractere, chamado de `"r"`, para que o tamanho da requisição fosse a menor possível, aumentando a taxa de amplificação do ataque.

Os ataques foram executados em diferentes níveis de intensidade, do 1 ao 7. Em cada nível, a quantidade de pacotes por segundo foi aumentada exponencialmente, de acordo com a equação (4), onde R significa o número de Requisições por segundo que a ferramenta teoricamente é capaz de enviar. A quantidade real varia de acordo com a capacidade do equipamento do atacante.

$$R = 10^{\text{nível}-1} \quad (4)$$

Os dispositivos utilizados nos testes estão descritos na tabela I, assim como os *softwares* relevantes para os ataques. O dispositivo do atacante foi quem realizou os ataques com a ferramenta, enviando pacotes de requisições para o refletor, que por sua vez rodava o servidor CoAP, que foi explorado pelo atacante para alcançar a vítima, que era o dispositivo alvo do atacante, recebendo o tráfego amplificado do refletor.

TABELA I. DISPOSITIVOS UTILIZADOS NOS ATAQUES

Atacante (PC Linux)	Refletor (Raspberry Pi 3 B+)	Vítima (Laptop Windows)
• Intel Core i9-9900KS @ 4.00GHz • 32GB DDR4 @ 2666MHz RAM • Adaptador GigabitEthernet Intel I219-V • Ubuntu 18.04 LTS x64 • tcpdump	• Cortex-A53 (ARMv8) 64-bit SoC @ 1.4GHz • 1GB LPDDR2 SDRAM • Adaptador GigabitEthernet sobre USB 2.0 (máximo de 300 Mbps) • Raspbian Buster Lite • CoAPthon 4.0.2 • tcpdump	• Intel Core i7-5500U @ 2.40GHz • 8GB DDR3L @ 1600MHz RAM • Adaptador GigabitEthernet Realtek PCIe • Windows 10 Pro Versão 1903 • Wireshark 2.4.2

Os três equipamentos foram interconectados por um roteador doméstico (Asus GT-AC5300), que atuou como um *switch*, a uma velocidade de 1 Gbps em cada porta, com exceção do Raspberry Pi, que possui limitação de velocidade a 300Mbps. O cenário exibido na figura 2 foi montado e os ataques foram realizados tanto sobre IPv4 quanto IPv6, com duração de 10 segundos em cada um dos níveis testados (1 a 7). Foram realizadas capturas de tráfego em todos os equipamentos envolvidos, via tcpdump ou Wireshark.

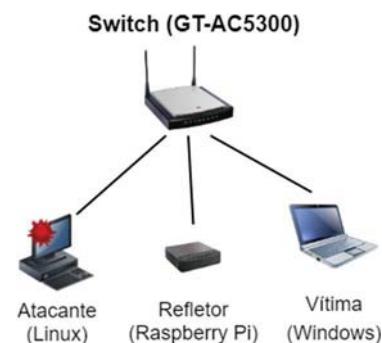


Figura 2. Cenário utilizado nos ataques AR-DDoS

TABELA II. ATAQUE COAP SOBRE IPV4

Nível	Enviados pelo atacante			Recebidos pelo refletor			Enviados pelo refletor			Recebidos pela vítima		
	Bytes	Kbps	Pacotes/s	Bytes	Kbps	Pacotes/s	Bytes	Kbps	Pacotes/s	Bytes	Kbps	Pacotes/s
1	360	0,3	1,0	360	0,3	1,0	21040	16,8	2,0	21040	16,8	2,0
2	3600	2,9	10,0	3600	2,9	10,0	210400	168,3	20,0	210400	168,3	20,0
3	36000	28,8	100,0	36000	28,8	100,0	1110912	888,7	105,6	1110912	888,7	105,6
4	360000	288,0	1000,0	351360	281,1	976,0	723776	579,0	68,8	723776	579,0	68,8
5	3600000	2880,0	10000,0	892620	714,1	2479,5	1150888	920,7	109,4	1150888	920,7	109,4
6	36000000	28800,0	100000,0	2162160	1729,7	6006,0	584912	467,9	55,6	584912	467,9	55,6
7	360000000	288000,0	1000000,0	15551892	12441,5	43199,7	669072	535,3	63,6	669072	535,3	63,6

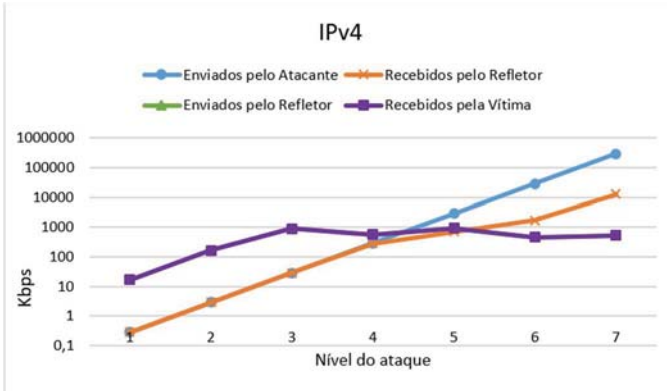


Figura 3. Ataque CoAP sobre IPv4 (Kbps)

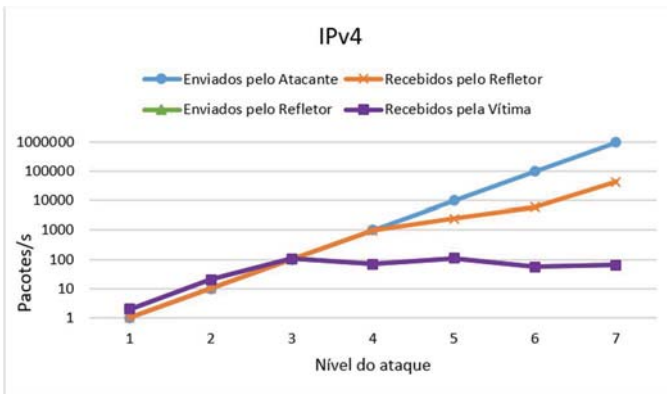


Figura 4. Ataque CoAP sobre IPv4 (Pacotes/s)

IV. RESULTADOS

Após a execução dos ataques, as capturas de tráfego foram analisadas e os resultados encontram-se descritos nas subseções a seguir. As mensagens enviadas foram do tipo CON, com respostas ACK do tipo *piggybacked*.

TABELA III. ATAQUE COAP SOBRE IPV6

Nível	Enviados pelo atacante			Recebidos pelo refletor			Enviados pelo refletor			Recebidos pela vítima		
	Bytes	Kbps	Pacotes/s	Bytes	Kbps	Pacotes/s	Bytes	Kbps	Pacotes/s	Bytes	Kbps	Pacotes/s
1	560	0,4	1,0	560	0,4	1,0	21600	17,3	2,0	21600	17,3	2,0
2	5600	4,5	10,0	5600	4,5	10,0	216000	172,8	20,0	216000	172,8	20,0
3	56000	44,8	100,0	56000	44,8	100,0	1114560	891,6	103,2	1114560	891,6	103,2
4	560000	448,0	1000,0	551880	441,5	985,5	982800	786,2	91,0	982800	786,2	91,0
5	2272480	1818,0	4058,0	1297464	1038,0	2316,9	855360	684,3	79,2	855360	684,3	79,2
6	5467560	4374,0	9763,5	2810640	2248,5	5019,0	855360	684,3	79,2	855360	684,3	79,2
7	22951992	18361,6	40985,7	11413080	9130,5	20380,5	639360	511,5	59,2	639360	511,5	59,2

A. Ataque sobre IPv4

A tabela II nos permite constatar alguns comportamentos interessantes quando o ataque foi realizado sobre IPv4. O primeiro diz respeito à capacidade de geração de tráfego do atacante, que em nenhum momento saturou, ou seja, ele foi capaz de gerar e enviar, em sua totalidade, a quantidade máxima de pacotes por segundo suportada pela ferramenta, conforme a equação (4).

Por outro lado, a partir do nível 4, o refletor não foi mais capaz de receber a mesma quantidade de pacotes e *bytes* enviados pelo atacante e, a partir do nível 3, não foi mais capaz de gerar respostas para a vítima na mesma taxa em que recebeu as requisições, indicando uma saturação ainda nos níveis iniciais testados, com uma quantidade relativamente pequena de Kbps e pacotes/s. A vítima, por sua vez, conseguiu receber e processar exatamente a mesma quantidade de dados enviados pelo refletor, não apresentando saturação.

As figura 3 e 4 ilustram bem esse comportamento de saturação do refletor a partir dos níveis 3 e 4, tanto no que diz respeito à quantidade de quilobits por segundo (Kbps) quanto na de pacotes por segundo.

B. Ataque sobre IPv6

Com a realização do ataque sobre IPv6, foi possível constatar outro padrão de comportamento do atacante, provavelmente devido ao tamanho maior do cabeçalho dos pacotes (40 *bytes* contra 20 *bytes* do IPv4). A tabela III mostra que a quantidade de dados enviados sobre IPv6 é em torno de 55% maior do que em relação ao IPv4, pelo menos até o nível 4, onde não ocorre saturação no atacante. A partir do nível 5 o atacante não é mais capaz de gerar pacotes na capacidade máxima da ferramenta, ainda que a quantidade de *bytes* não seja tão elevada, podendo indicar uma limitação na pilha TCP/IPv6 do sistema operacional.

Assim como no IPv4, a partir do nível 4, o refletor não foi mais capaz de receber a mesma quantidade de pacotes/s enviados pelo atacante. No nível 4, essa taxa foi 1% melhor, mas nos demais níveis foi bem inferior. A partir do nível 3, o refletor apresentou o mesmo padrão de saturação do IPv4, onde não foi capaz de gerar respostas para a vítima na mesma taxa em que recebeu as requisições. A vítima, nesse cenário, também não apresentou saturação, sendo capaz de processar todos os pacotes enviados pelo refletor.

As figuras 5 e 6 também ilustram o comportamento de saturação do refletor a partir dos níveis 3 e 4. Entretanto, a taxa de Kbps recebida pela vítima é um pouco maior no IPv6, com exceção dos níveis 5 e 7.

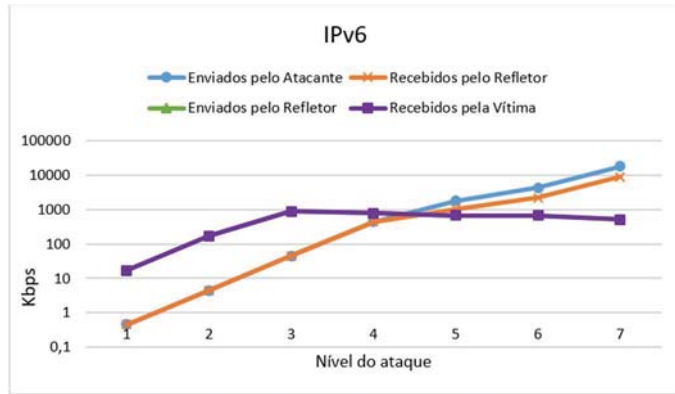


Figura 5. Ataque CoAP sobre IPv6 (Kbps)

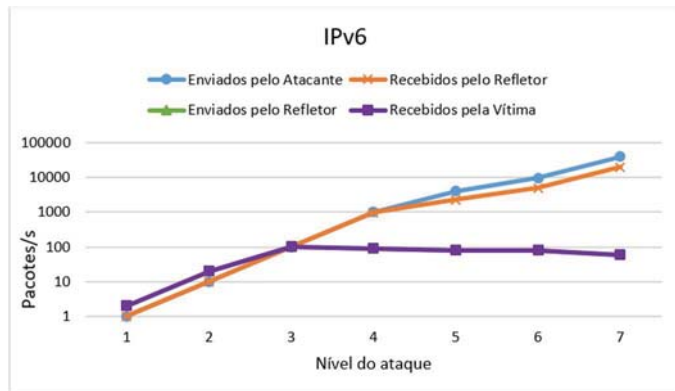


Figura 6. Ataque CoAP sobre IPv6 (Pacotes/s)

Com relação à amplificação em pacotes/s, o comportamento do refletor segue idêntico à amplificação em Kbps tanto para IPv4 quanto para IPv6.

C. Fatores de Amplificação

A tabela IV resume todas as taxas de amplificação calculadas nos ataques com CoAP a partir dos dados coletados nas capturas, segundo as equações (1) e (2). As taxas de amplificação de *bytes* para IPv4 foram ligeiramente maiores do que em relação ao IPv6, mas somente até o momento em que houve saturação do refletor, depois elas ficaram muito próximas. Esse comportamento é devido ao cabeçalho IPv4 ter a metade do tamanho do IPv6, gerando requisições bem menores. As taxas de amplificação de pacotes, por outro lado,

se mantiveram compatíveis nas duas versões do protocolo IP, conforme se comprova nas figuras 7 e 8.

TABELA IV. FATORES DE AMPLIFICAÇÃO

Nível	Amplificação de Bytes		Amplificação de Pacotes	
	IPv4	IPv6	IPv4	IPv6
1	58,444	38,571	2,000	2,000
2	58,444	38,571	2,000	2,000
3	30,859	19,903	1,056	1,032
4	2,060	1,781	0,070	0,092
5	1,289	0,659	0,044	0,034
6	0,271	0,304	0,009	0,016
7	0,043	0,056	0,001	0,003

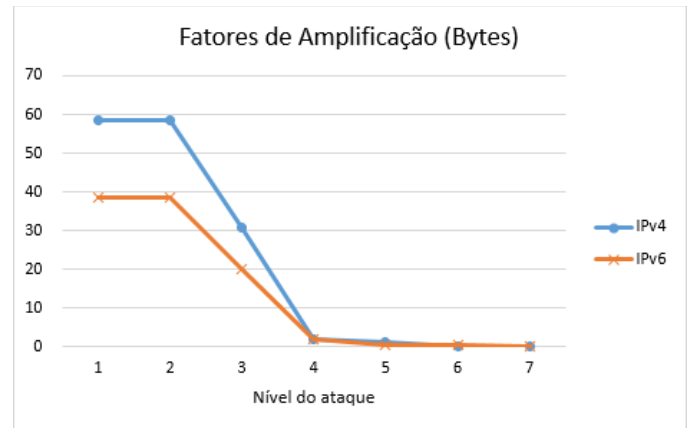


Figura 7. Fatores de Amplificação de Bytes dos Ataques

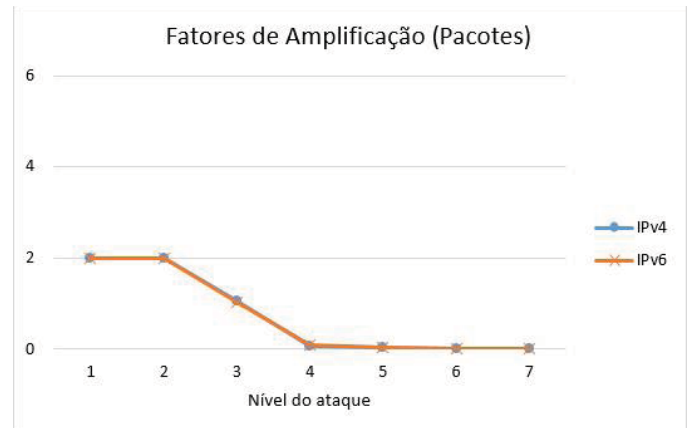


Figura 8. Fatores de Amplificação de Pacotes dos Ataques

D. Discussão

Como demonstram os resultados obtidos, o comportamento geral do refletor é consistente com o relatado em trabalhos anteriores ([11], [12], [13], [14] e [15]). Deve-se notar que esses trabalhos envolveram protocolos e configurações de refletores. Especificamente, a saturação do refletor se deu, tanto em IPv4 quanto IPv6, no mesmo ponto: se inicia no nível 2 de ataque e se consolida no nível 3. Ou seja, o comportamento comum de saturação para níveis relativamente baixos de injeção de *probes* é corroborado.

Deve-se ressaltar que o FA obtido foi graças ao dispositivo aceitar requisições com valor SZX igual a 7, que engana o servidor CoAP para indicar que as respostas devem ter 2048 bytes de tamanho, o que não é aceito por todas as implementações do CoAP. Além disso, geralmente os tamanhos dos recursos encontrados em dispositivos com CoAP costumam ser menores de 1024 bytes. Assim, em um ataque “*in the wild*” espera-se observar um FA bem menor.

Por fim, o FA menor para o ataque sobre IPv6 é consistente com o esperado devido ao seu cabeçalho maior que o do IPv4.

V. CONCLUSÕES

Os resultados obtidos mostram que o ataque AR-DDoS explorando CoAP sobre dispositivo IoT configura uma ameaça que não pode ser desprezada. Ainda que o FA obtido seja entre médio e baixo, o grande número de dispositivos, em sua maioria móveis, executando aplicações sobre CoAP, oferece uma superfície de ataque significativa. O fato de uma parte destes dispositivos utilizarem IPv6 para conectividade não ameniza a ameaça, dada a dimensão da base de dispositivos disponíveis e, mesmo que estes utilizem endereçamento dinâmico, forçando varreduras próximas à realização de ataques para identificação de refletores, o que poderia reduzir a ocorrência de ataques, isso não desencorajou o ataque relatado em [7].

Como possíveis medidas mitigatórias, indica-se o uso de valores baixos para o campo SZX na requisição CoAP, com consequente limitação do tamanho do pacote de resposta. Outra possível medida seria a limitação dos recursos do equipamento reportados pelo CoAP, juntamente com uso de nomes de caminho longos. O efeito destas medidas, isolada ou combinadamente, seria reduzir o FA de forma a tornar o ataque menos atrativo que outras formas de AR-DDoS que exploram outros protocolos com altas taxas de amplificação. Note-se ainda que no estado atual estas medidas deveriam ser implementadas pelas aplicações que usam CoAP. Tais medidas são um tópico de pesquisa para trabalhos futuros.

Com respeito a este trabalho se limitar a testar apenas um dispositivo, temos como desdobramentos deste a realização dos testes em outros cenários, envolvendo outros dispositivos e formas de conectividade, de maneira a estudar o comportamento em equipamentos distintos para caracterização da saturação. Meios como Wi-Fi e fibra óptica poderiam ser melhor analisados, uma vez que dispositivos IoT estão frequentemente conectados através deles. No caso da fibra óptica, nos referimos a terminais GPON, que comumente são utilizados em conexões do tipo *Fiber to The Home* (FTTH).

REFERÊNCIAS BIBLIOGRÁFICAS

- [1] Bright, P.: "Spamhaus DDoS Grows to Internet-Threatening Size", *Arstechnica*, <http://arstechnica.com/security/2013/03/spamhaus-ddos-grows-to-internetthreatening-size/>, 2013 (accessed on 12 May 2016).
- [2] Prince, M.: "The DDoS That Knocked Spamhaus Offline (and How We Mitigated It)", Cloudflare blog, <https://blog.cloudflare.com/the-ddos-that-knocked-spamhaus-offline-and-how/>, 2013 (accessed on May 2016).
- [3] Goodin, D.: "Record-Breaking DDoS Reportedly Delivered by >145k Hacked Cameras", *Arstechnica*, <http://arstechnica.com/security/2016/09/botnet-of-145k-cameras-reportedly-deliver-internets-biggest-ddos-ever>, accessed on Oct 2016.
- [4] Akamai: "MEMCACHED-FUELED 1.3 TBPS ATTACKS", <https://blogs.akamai.com/2018/03/memcached-fueled-13-tbps-attacks.html>, accessed on Nov 2019.
- [5] NETSCOUT Arbor: <https://br.netscout.com/blog/asert/netscout-arbor-confirms-17-tbps-ddos-attack-terabit-attack-era>, accessed on Oct 2016.
- [6] RFC7252. The Constrained Application Protocol (CoAP). RFC Editor, 2014. Disponível em: <<https://rfc-editor.org/rfc/rfc7252.txt>>.
- [7] NETSCOUT Arbor: <https://www.netscout.com/blog/asert/coap-attacks-wild>, accessed on Oct 2019.
- [8] Ferreira, H. G. C.; de Sousa Jr, R. T. Security analysis of a proposed internet of things middleware. *Cluster Computing* 2017. DOI: 10.1007/S10586-017-0729-3.
- [9] Paxson, V.: "An Analysis of Using Reflectors for Distributed Denial-of-Service Attacks", in *ACM SIGCOMM Computer Commun. Rev.*, vol. 31, pp. 38–47, 2001.
- [10] Rossow, C.: "Amplification Hell: Revisiting Network Protocols for DDoS Abuse", in *Proceedings of the 21st Annual Network and Distributed System Security Symposium, NDSS 2014*, San Diego, CA, USA, pp. 23–26, February 2014, doi: 10.14722/ndss.2014.23233.
- [11] Pacheco, L. A. B., Gondim, J. J. C., Barreto, P. A. S., Alchieri, E.: "Evaluation of Distributed Denial of Service threat in the Internet of Things", in *2016 IEEE 15th International Symposium on Network Computing and Applications (NCA)*, pp. 89-92, Oct. 2016.
- [12] Gondim, J. J. C., de Oliveira Albuquerque, R., Clayton Alves Nascimento, A., García Villalba, L., Kim, T. H.: "A methodological approach for assessing amplified reflection distributed denial of service on the internet of things", in *Sensors*, vol. 16, n. 11, p. 1855, 2016.
- [13] Gondim, J.J.C., Albuquerque, R. de O.; "Mirror Saturation in Amplified Reflection DDoS"; In *Actas de las V Jornadas Nacionales de Ciberseguridad: Junio 5-7, 2019, Cáceres, España*. Ed. Caro Lindo, Andrés and García Villalba, Luis Javier and Sandoval Orozco, Ana Lucila, Universidad de Extremadura, Servicio de Publicaciones, 2019.
- [14] Vasques, Alan Tamer, and João J C Gondim. "Amplified Reflection DDoS Attacks over IoT Mirrors: A Saturation Analysis." *2019 Workshop on Communication Networks and Power Systems (WCNPS)*. IEEE, 2019.
- [15] GONDIM, João J. C.; DE OLIVEIRA ALBUQUERQUE, Robson; OROZCO, Ana Lucila Sandoval. Mirror saturation in amplified reflection Distributed Denial of Service: A case of study using SNMP, SSDP, NTP and DNS protocols. *Future Generation Computer Systems*, 2020. <https://doi.org/10.1016/j.future.2020.01.024>.
- [16] Internet Society. Addressing the Challenge of IP Spoofing. 2015. Disponível em: <https://www.internetsociety.org/resources/doc/2015/addressing-the-challenge-of-ip-spoofing/>. Acessado em: 10/02/2020.
- [17] RFC7959. BLOCK-WISE Transfers in the Constrained Application Protocol (CoAP). RFC Editor, 2016. Disponível em: <<https://rfc-editor.org/rfc/rfc7959.txt>>.